

11

Triển khai

Audit CSDL Oracle

Mục tiêu

Sau bài học hôm nay, bạn có thể:

- Hiểu được trách nhiệm của DBA với việc an toàn và audit CSDL Oracle
- Bật tính năng audit
- Tạo các chính sách audit
- Quản lý các log audit sinh ra

Bảo mật CSDL

Một hệ thống an toàn sẽ phải đảm bảo tính bảo mật dữ liệu. Một số tiêu chí như sau:

- Xác thực người dùng
- Hạn chế người dùng truy cập dữ liệu và dịch vụ
- Giám sát tác động của người dùng



Giám sát

- Giám sát và audit là một phần trong công tác bảo mật CSDL
- Bao gồm:
 - Audit bắt buộc
 - Audit CSDL theo đúng chuẩn
 - Audit dựa trên giá trị dữ liệu (dùng trigger)
 - Fine-grained auditing (FGA)



Các hoạt động cần audit

Các hoạt động dưới đây cần audit:

- Tài khoản người dùng, role, và quyền
- Các tác động vào Object
- Các giá trị theo từng ứng dụng
- Oracle Data Pump
- Oracle Database Real Application Security
- Oracle Database Vault
- Oracle Label Security
- Oracle Recovery Manager
- Load dữ liệu từ Oracle SQL*Loader

Các hoạt động bắt buộc audit

Các hoạt động dưới đây được audit:

- CREATE/ALTER/DROP AUDIT POLICY
- AUDIT/NOAUDIT
- EXECUTE của gói:
 - DBMS_FGA
 - DBMS_AUDIT_MGMT
- ALTER TABLE bảng audit trail AUDSYS
- Các câu lệnh mức cao bởi các user quản trị SYS, SYSDBA, SYSOPER, SYSASM, SYSBACKUP, SYSDG, và SYSKM cho đến khi CSDL được mở

Hiểu về cách triển khai audit

- *Mixed mode auditing* là mặc định trong CSDL Oracle 12c khi CSDL được tạo ra
- Mixed mode auditing cho phép sử dụng:
 - Các tính năng audit trước phiên bản Oracle Database 12c
 - Tính năng unified auditing trong Oracle Database 12c
- Oracle khuyến cáo chuyển unified auditing.
- Truy vấn view `V$OPTION` để kiểm tra sau khi được chuyển unified auditing:

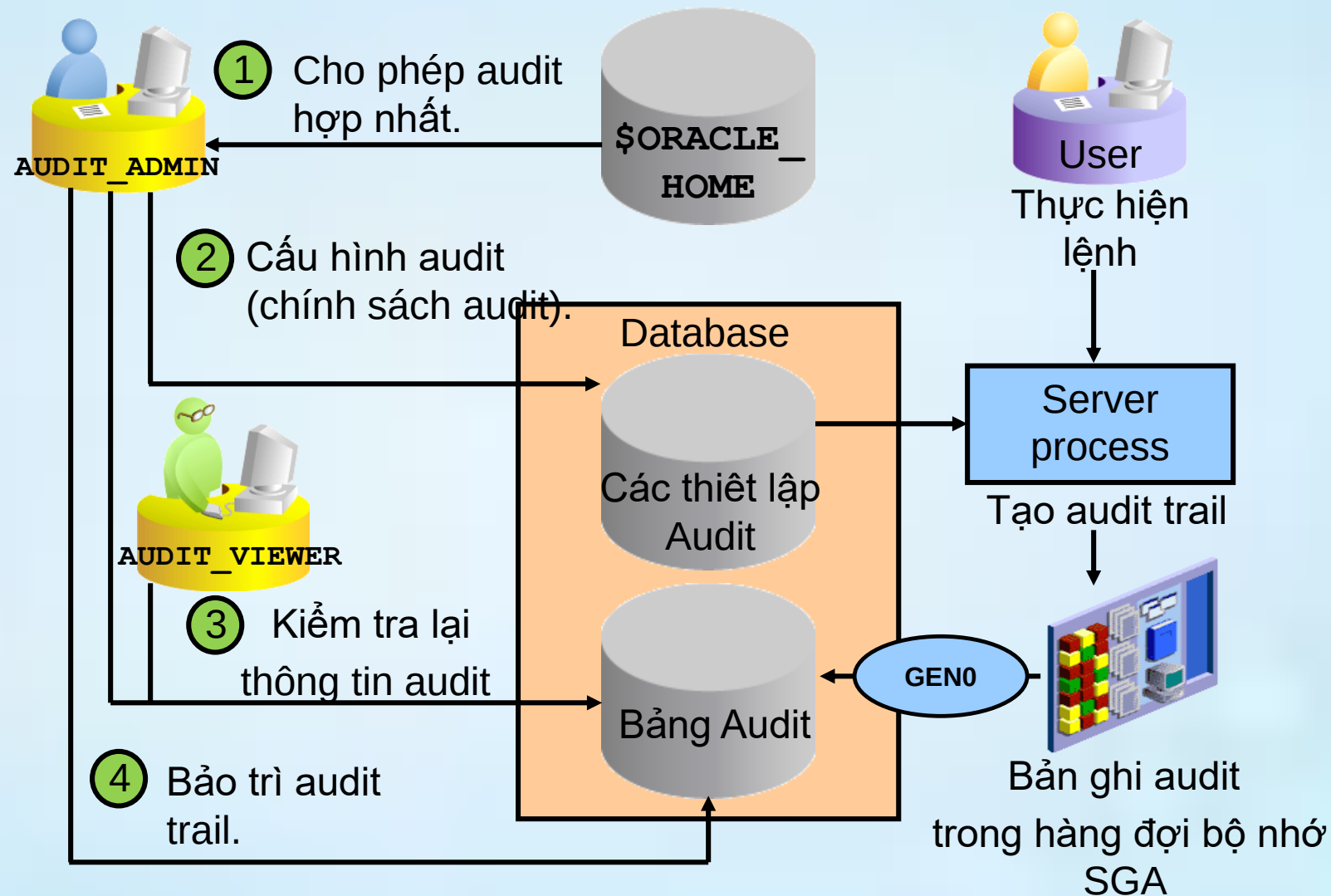
```
SELECT value FROM v$option  
WHERE parameter = 'Unified Auditing'
```

Quản lý các role cần thiết cho hoạt động audit

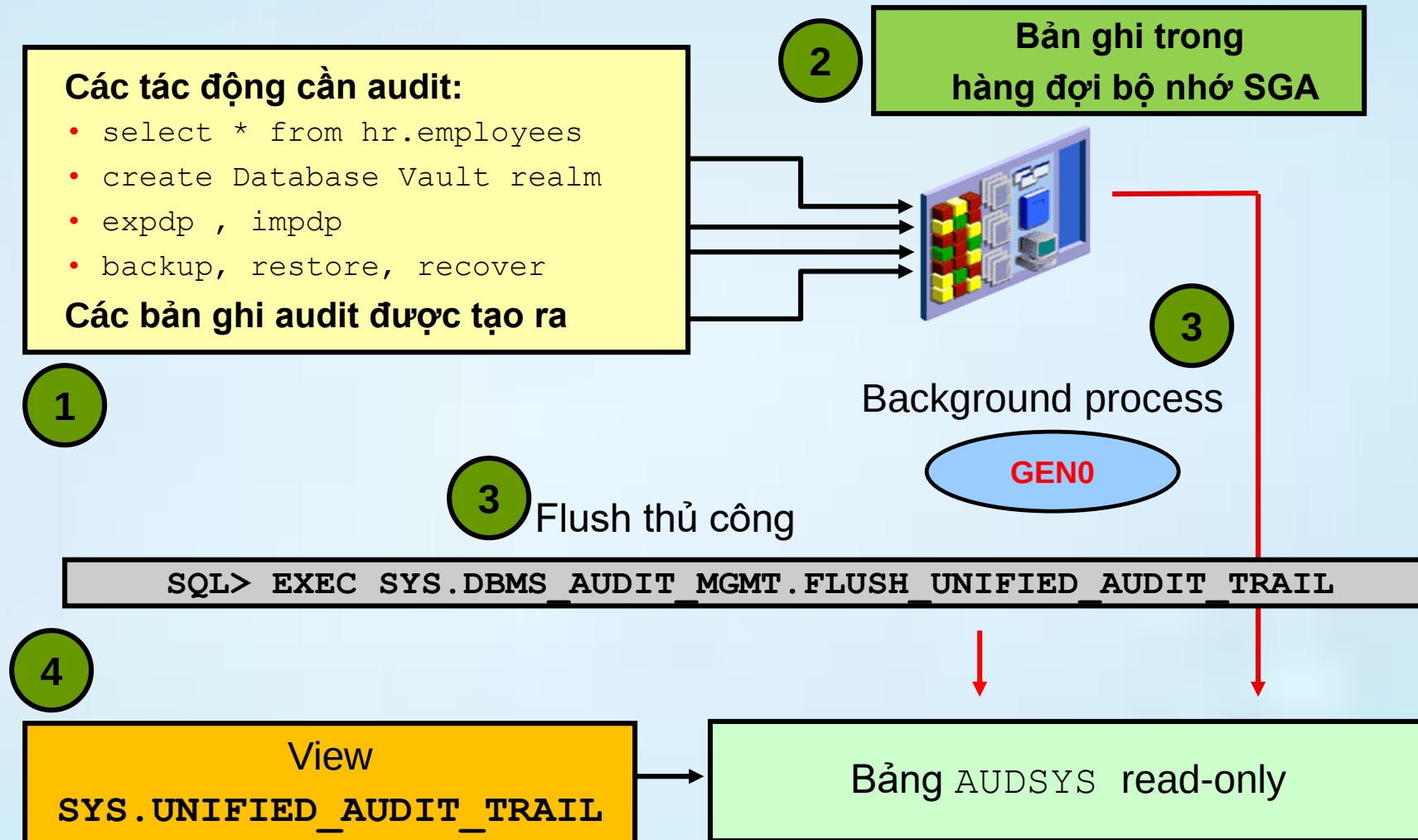
Một người dùng được gán một trong các role sau để thực hiện audit:

- `AUDIT_ADMIN` cho phép người dùng:
 - Tạo các luật unified và fine-grained audit
 - Thực hiện các câu lệnh SQL `AUDIT` và `NOAUDIT`
 - Hiển thị dữ liệu audit
 - Quản lý audit trail (bảng trong schema `AUDSYS`)
- `AUDIT_VIEWER` cho phép người dùng:
 - Hiển thị và phân tích dữ liệu audit

Tổng quan về Audit CSDL



Tìm hiểu kiến trúc Audit



Cho phép Audit hợp nhất

1. Trong SQL*Plus, tắt instance CSDL:

```
SQL> SHUTDOWN IMMEDIATE
```

2. Tắt listener:

```
$ lsnrctl stop
```

3. Tại dấu nhắc OS, cho phép thực thi unified auditing :

```
$ cd $ORACLE_HOME/rdbms/lib  
$ make -f ins_rdbms.mk uniaud_on ioracle ORACLE_HOME=$ORACLE_HOME
```

4. Restart listener:

```
$ lsnrctl start
```

5. Trong SQL*Plus, restart lại instance CSDL:

```
SQL> STARTUP
```

Cấu hình Audit

Phương thức	Mô tả
Chính sách Unified audit	Thiết lập group audit trong chính sách
Chính sách unified audit mặc định	3 chính sách mặc định: ORA_SECURECONFIG ORA_DATABASE_PARAMETER_AUDIT ORA_ACCOUNT_MGMT_AUDIT
Chính sách Fine-grained audit (FGA)	Định nghĩa các điều kiện xác định phải thỏa mãn khi hoạt động audit được diễn ra

Sử dụng Enterprise Manager Cloud Control

The screenshot displays the Oracle Enterprise Manager Cloud Control interface. The 'Administration' menu is open, showing options like Initialization Parameters, Security, Storage, Oracle Scheduler, Streams and Replication, Migrate to ASM, Resource Manager, and Database Feature Usage. The 'Security' sub-menu is expanded, highlighting 'Audit Settings'. The main content area shows the 'Audit Settings' page for the 'orcl' database, with a 'General' tab selected. It displays audit mode (Unified), policies (1/4 enabled), last archived on (null), last purged on (N/A), OS audit files (17), and tablespace (SYSAUX(3.18% Full)). A table at the bottom lists audit policies and their associated system privileges, roles, component actions, object actions, conditional settings, enabled status, audit scope, and users.

Audit Policy	System Privileges	Roles	Component Actions	Object Actions	Conditional	Enabled	Audit	Users
ORA_SECURECONFIG	29	0	15	0		✓	All	
ORA_RAS_POLICY_MGMT	0	0	32	0				
ORA_RAS_SESSION_MGMT	0	0	14	0				
ORA_ACCOUNT_MGMT	0	0	9	0				
ORA_DATABASE_PARAMETER	0	0	3	0				

Tạo chính sách Audit hợp nhất

- Sử dụng câu lệnh CREATE AUDIT POLICY:

```
CREATE AUDIT POLICY select_emp_pol  
ACTIONS select on hr.employees
```

- Sử dụng Enterprise Manager Cloud Control:

Create Audit Policy : Privileges And Roles

* Name: select_emp_pol

Comments: Audit policy for SELECT statements on HR.EMPLOYEES

Create Audit Policy : Object Actions

Specify object specific actions to be audited by this policy. The audit can include both DDL and DML statements that were used on the object.

+ Add Object - Remove Object

Type	Action	Schema	Name
TABLE	SELECT	HR	EMPLOYEES

Tạo chính sách Audit: Tùy chọn audit mức hệ thống

- Quyền hệ thống:

```
CREATE AUDIT POLICY audit_syspriv_pol1  
PRIVILEGES SELECT ANY TABLE, CREATE LIBRARY
```

- Tác động:

```
CREATE AUDIT POLICY audit_actions_pol2  
ACTIONS AUDIT, ALTER TRIGGER
```

- Role:

```
CREATE AUDIT POLICY audit_role_pol3  
ROLES mgr_role
```

- System privilege, tác động và role:

```
CREATE AUDIT POLICY audit_mixed_pol4  
PRIVILEGES DROP ANY TABLE  
ACTIONS      CREATE TABLE, DROP TABLE, TRUNCATE TABLE  
ROLES        emp_role
```

Tạo chính sách Audit: Tác động cho object

Tạo chính sách audit dựa trên object:

```
CREATE AUDIT POLICY audit_objpriv_pol5  
ACTIONS SELECT, UPDATE, LOCK ON hr.employees
```

```
CREATE AUDIT POLICY audit_objpriv_pol6  
ACTIONS ALL
```

```
CREATE AUDIT POLICY audit_objpriv_pol7  
ACTIONS EXECUTE, GRANT ON hr.raise_salary_proc
```


Tạo chính sách Audit: Điều kiện xác định

- Điều kiện và đánh giá **PER SESSION**

```
CREATE AUDIT POLICY audit_mixed_pol5  
ACTIONS RENAME ON hr.employees,ALTER ON hr.jobs,  
WHEN 'SYS_CONTEXT (''USERENV'', ''SESSION_USER'')=' 'JIM' '  
EVALUATE PER SESSION
```

- Điều kiện và đánh giá **PER STATEMENT**

```
CREATE AUDIT POLICY audit_objpriv_pol6  
ACTIONS ALTER ON OE.ORDERS  
WHEN 'SYS_CONTEXT (''USERENV'', ''CLIENT_IDENTIFIER'')=' 'OE' '  
EVALUATE PER STATEMENT
```

- Điều kiện và đánh giá **PER INSTANCE**

```
CREATE AUDIT POLICY audit_objpriv_pol7  
ROLES dba  
WHEN SYS_CONTEXT (''USERENV'', ''INSTANCE_NAME'')=' 'sales' '  
EVALUATE PER INSTANCE
```

Bật và tắt chính sách Audit

Bật chính sách audit:

- Áp dụng cho mọi user

```
SQL> AUDIT POLICY audit_syspriv_pol1;
```

- Áp dụng cho một số user

```
SQL> AUDIT POLICY audit_pol2 BY scott, oe;
```

```
SQL> AUDIT POLICY audit_pol3 BY sys;
```

- Loại trừ một số user

```
SQL> AUDIT POLICY audit_pol4 EXCEPT jim, george;
```

- Audit với tác động lỗi hoặc thành công:

```
SQL> AUDIT POLICY audit_syspriv_pol1 WHENEVER SUCCESSFUL ;
```

```
SQL> AUDIT POLICY audit_objpriv_pol2 WHENEVER NOT SUCCESSFUL ;
```

```
SQL> AUDIT POLICY auditpol5 BY joe WHENEVER SUCCESSFUL ;
```

Tắt chính sách audit bằng câu lệnh NOAUDIT

Thay đổi chính sách Audit hợp nhất

- Sử dụng câu lệnh ALTER AUDIT POLICY:

```
ALTER AUDIT POLICY select_emp_pol  
ADD ACTIONS select on hr.job_history
```

- Sử dụng Enterprise Manager Cloud Control:

Create Create Like Edit Delete Show Enable Disable									
Audit Policy	System Privileges	Roles	Component Actions	Object Actions	Conditional	Enabled	Audit	Users	
ORA_SECURECONFIG	29	0	15	0			All		
ORA_RAS_POLICY_MGMT	0	0	32	0					
ORA_RAS_SESSION_MGMT	0	0	14	0					
ORA_ACCOUNT_MGMT	0	0	9	0					
ORA_DATABASE_PARAMETER	0	0	3	0					
SELECT_EMP_POL	0	0	0	1			By	HR	
Rows Selected 1									

Hiển thị thông tin chính sách Audit

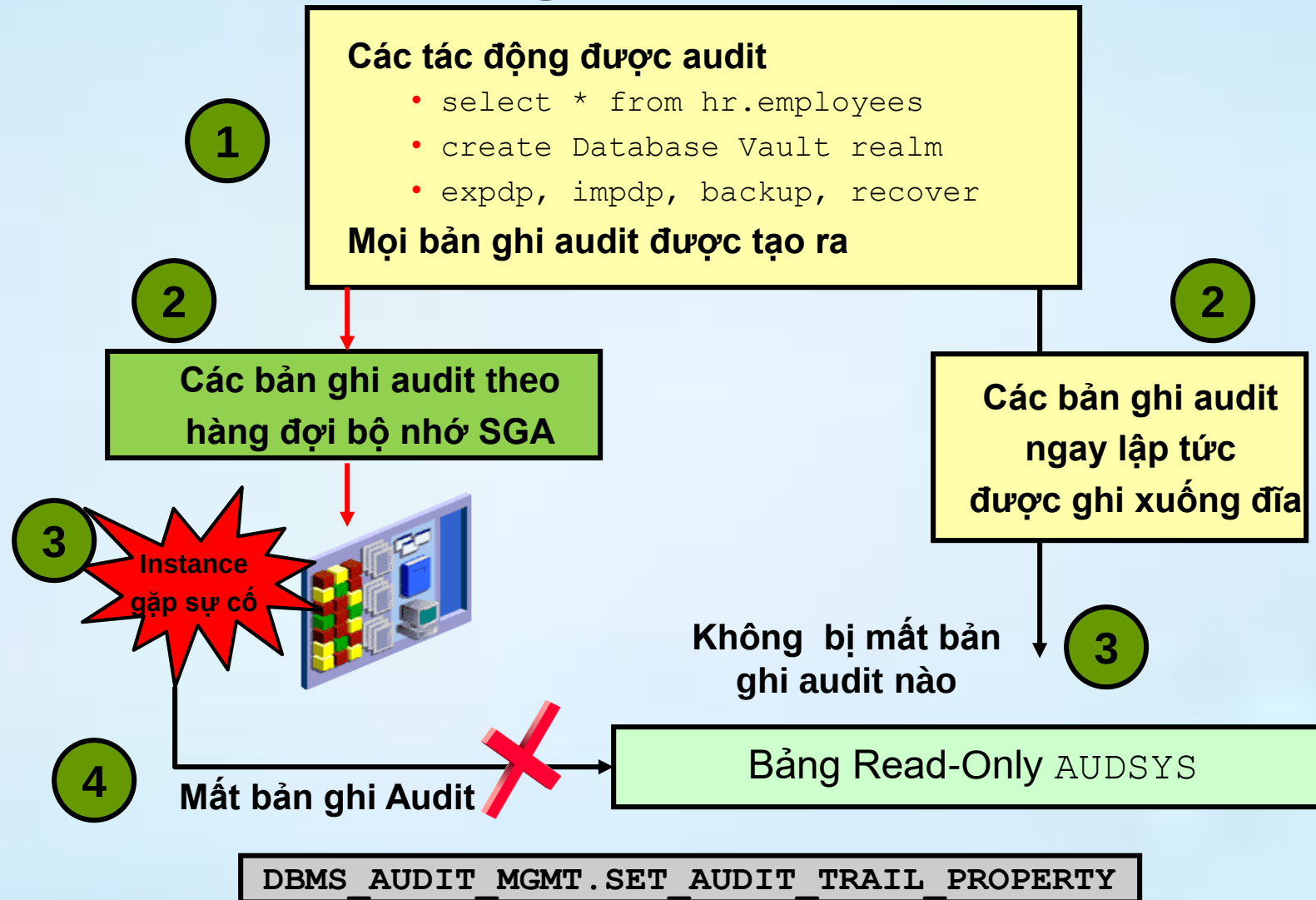
```
SQL> SELECT policy_name, audit_option, condition_eval_opt
2 FROM audit_unified_policies;
```

POLICY_NAME	AUDIT_OPTION	CONDITION_EVAL_OPT
-----	-----	-----
POL1	DELETE	INSTANCE
POL2	TRUNCATE TABLE	NONE
POL3	RENAME	SESSION
POL4	ALL ACTIONS	STATEMENT

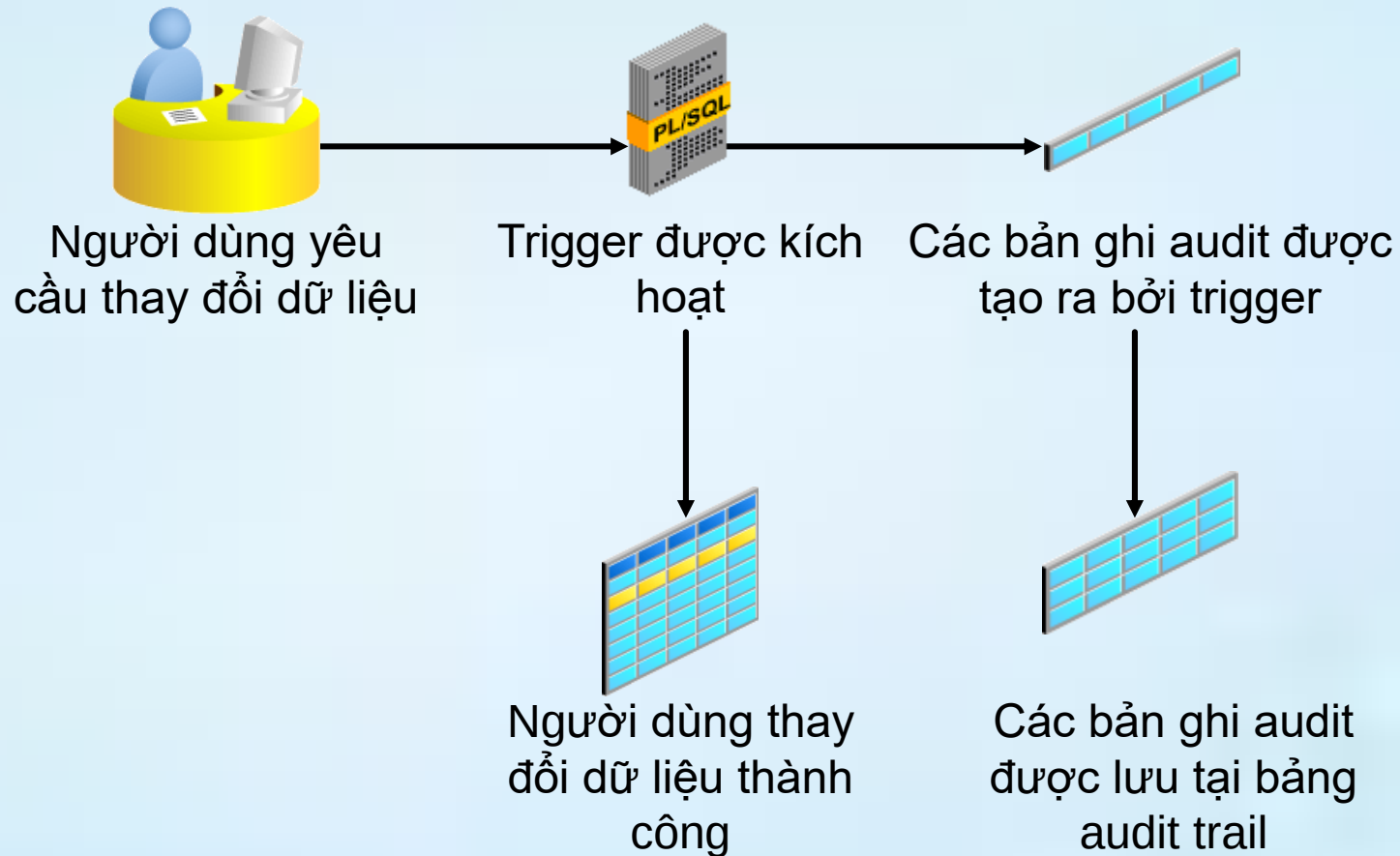
```
SQL> SELECT policy_name, enabled_opt, user_name, success, failure
2 FROM audit_unified_enabled_policies;
```

POLICY_NAME	ENABLED_	USER_NAME	SUC	FAI
-----	-----	-----	---	---
POL3	BY	PM	NO	YES
POL2	EXCEPT	SYSTEM	NO	YES
POL4	BY	SYS	YES	YES
POL6	BY	ALL USERS	YES	NO

Thiết lập chế độ ghi với dữ liệu Audit Trail

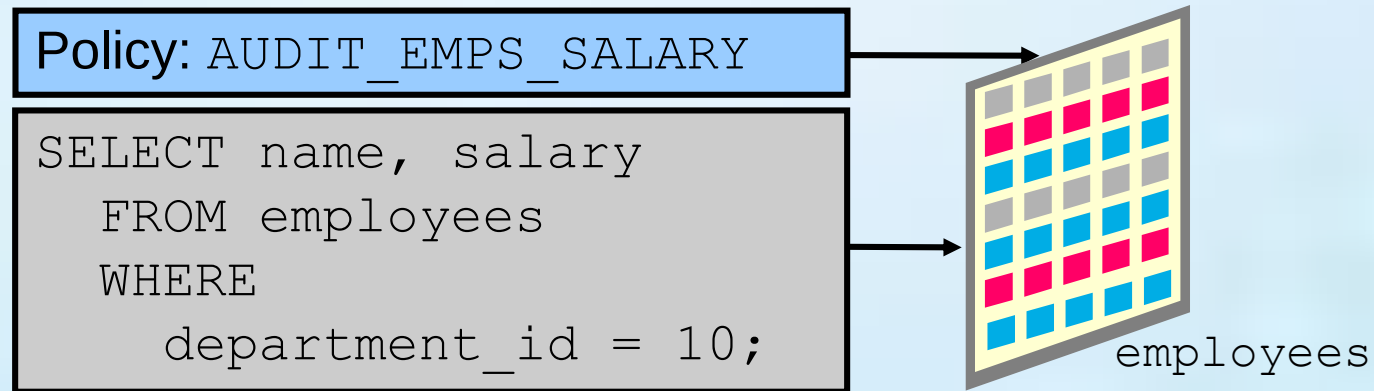


Audit dựa trên dữ liệu



Fine-Grained Auditing (FGA)

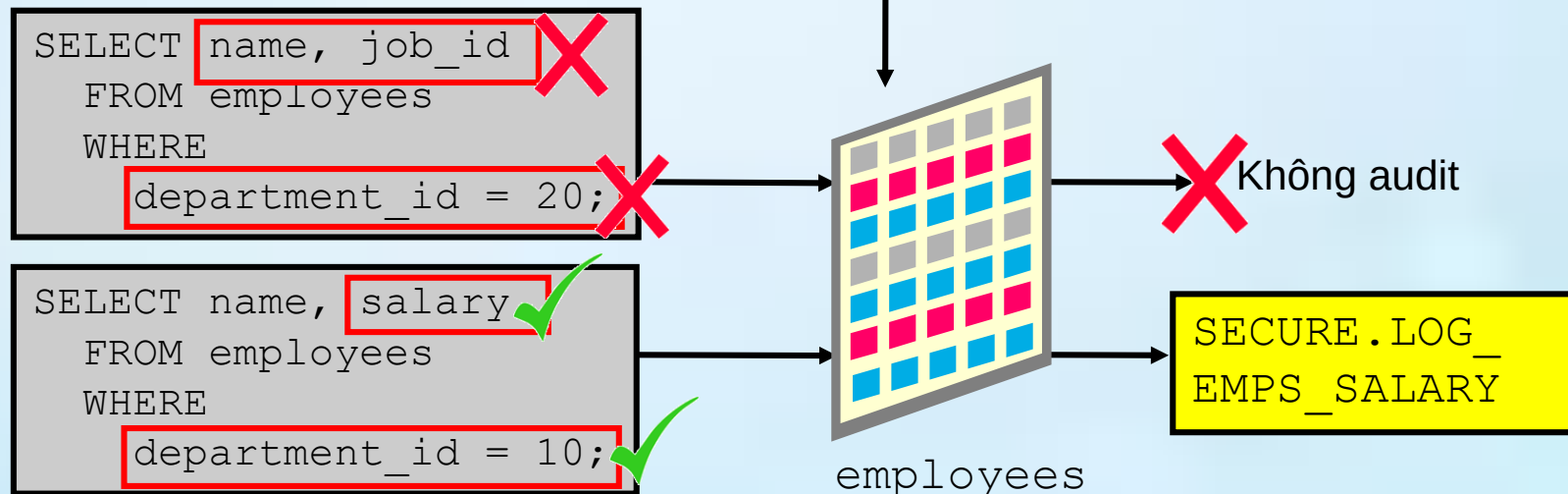
- Giám sát truy cập dữ liệu dựa trên điều kiện nhất định
- Audit các tác động `SELECT`, `INSERT`, `UPDATE`, `DELETE` và `MERGE`
- Có thể 1 hoặc vài cột trong bảng hoặc view
- Có thể thực thi một thủ tục
- Được quản trị với gói `DBMS_FGA`



Chính sách FGA

- Định nghĩa:
 - Điều kiện Audit
 - Tác động Audit
- Được tạo ra với
DBMS_FGA.ADD_POLICY

```
dbms_fga.add_policy (  
  object_schema => 'HR',  
  object_name   => 'EMPLOYEES',  
  policy_name  => 'audit emps salary',  
  audit_condition=> 'department_id=10',  
  audit_column  => 'SALARY, COMMISSION_PCT',  
  handler_schema => 'secure',  
  handler_module => 'log_emps_salary',  
  enable       => TRUE,  
  statement_types => 'SELECT, UPDATE');
```



Audit câu lệnh DML

- Các bản ghi được audit khi FGA thỏa mãn các cột trong chính sách.
- Câu lệnh DELETE được audit theo các cột trong chính sách
- Câu lệnh MERGE được audit cùng với các câu lệnh INSERT, UPDATE và DELETE được tạo ra.

```
UPDATE hr.employees  
SET salary = 1000  
WHERE commission_pct = .2;
```

Không được audit bởi vì
không có nhân viên nào
trong phòng số 10



```
UPDATE hr.employees  
SET salary = 1000  
WHERE employee_id = 200;
```

Được audit bởi vì nhân
viên trong phòng số 10



Hướng dẫn quản lý FGA

- Để audit cả bảng, sử dụng điều kiện audit là *null*.
- Để audit mọi dữ liệu của một số cột, sử dụng điều kiện `null` trên cột đó.
- Tên của chính sách phải duy nhất.
- Bảng hoặc view được audit phải tồn tại trước khi tạo chính sách.
- Nếu cú pháp điều kiện không hợp lệ, lỗi `ORA-28112` khi object audit được truy cập.
- Nếu cột audit không tồn tại trong bản, không có dòng nào được audit.
- Nếu điều khiển sự kiện (event handler) không tồn tại, không có lỗi trả về và bản ghi audit vẫn được tạo.

Lưu giữ và xóa log Audit

- Định kỳ lưu trữ và xóa log audit để ngăn chặn sự tăng dung lượng log
- Lưu trữ log cũ bằng cách:
 - Sao chép các bản ghi audit sang bảng khác
 - Dùng Oracle Audit Vault
- Xóa audit trail bằng cách:
 - Tạo và lên lịch xóa theo thời gian định kỳ sử dụng thủ tục PL/SQL
`DBMS_AUDIT_MGMT.CREATE_PURGE_JOB`
 - Thủ công sử dụng thủ tục PL/SQL
`DBMS_AUDIT_MGMT.CLEAN_AUDIT_TRAIL`

Xóa các bảng ghi log Audit

- Đặt job tự động xóa định kỳ:

```
DBMS_AUDIT_MGMT.CREATE_PURGE_JOB  
(AUDIT_TRAIL_TYPE=> DBMS_AUDIT_MGMT.AUDIT_TRAIL_UNIFIED,  
  AUDIT_TRAIL_PURGE_INTERVAL => 12,  
  AUDIT_TRAIL_PURGE_NAME => 'Audit_Trail_PJ',  
  USE_LAST_ARCH_TIMESTAMP => TRUE,  
  CONTAINER => DBMS_AUDIT_MGMT.CONTAINER_CURRENT) ;
```

- Thủ công xóa các bản ghi log audit:

```
DBMS_AUDIT_MGMT.CLEAN_AUDIT_TRAIL(  
  AUDIT_TRAIL_TYPE => DBMS_AUDIT_MGMT.AUDIT_TRAIL_UNIFIED)
```

Câu hỏi

Câu lệnh mức cao thực hiện trước khi CSDL mở bởi các người dùng quản trị như SYS, SYSDBA bắt buộc phải audit?

a. Đúng.

b. Sai

Tổng kết

Trong bài học này, bạn đã được học:

- Hiểu được trách nhiệm của DBA với việc an toàn và audit CSDL Oracle
- Bật tính năng audit
- Tạo các chính sách audit
- Quản lý các log audit



Thực hành

Thực hành các nội dung sau:

- Tạo policy FGA
- Kiểm tra lại các thông tin audit
- Bảo trì log audit